

Denial of Service (DoS)

Hiraku Morita

4 Mar. 2026

Short-term memory to long-term memory

Recall what we did last week

5f4**dcc**3**b**5**aa****765**d61d8327deb882cf**99**

Short-term memory to long-term memory

Recall what we did last week

5f4**dcc3b5aa765**d61d8327deb882cf**99**

<— MD5(“password”)

Short-term memory to long-term memory

Recall what we did last week

5f4dcc3b5aa765d61d8327deb882cf99

← MD5("password")

' OR 1=1# What is this # for?

Short-term memory to long-term memory

Recall what we did last week

5f4dccc3b5aa765d61d8327deb882cf99

<— MD5(“password”)

' OR 1=1# What is this # for?
... to comment-out the rest

Short-term memory to long-term memory

Recall what we did last week

5f4dccc3b5aa765d61d8327deb882cf99

← MD5("password")

' OR 1=1# What is this # for?
... to comment-out the rest

Agenda

- Insecurity of the Week
- Continuing on attacks
- (Distributed) Denial of Service ((D)DoS) attacks
- Applying brute force

Insecurity of the Week

—A MitID DOS—

Front Matter

= ING/**VERSION2** ▾

Uhyre simpelt hack kan gætte brugernavne og blokere adgangen til MitID

PLUS | Cybersikkerhed | 30. september kl. 04:00 | 39



Flere eksperter er forundrede over de svagheder, der findes i MitID. Illustration: Nanna Skytte.

Eksperter fra både det private og offentlige kritiserer MitID for at være designet usikkert efter ny afdækning af flere svagheder i systemet. Datatilsynet undersøger sagen.

Summary

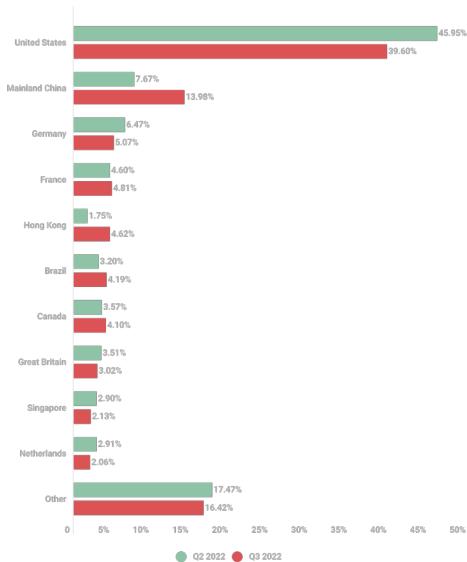
- With publication in media: very little detail known
- Despite rather lurid media activity from Version2
- **Guessing usernames possible**
(a non-existing UID is immediately confirmed)
- 11.000 user names in one night without being blocked
- **DoS against 17 users**
(who gave consent)
- Possibility of getting someone to “swipe”?
- Rather **lacking logging & surveillance?**

(Distributed) Denial of Service Attacks

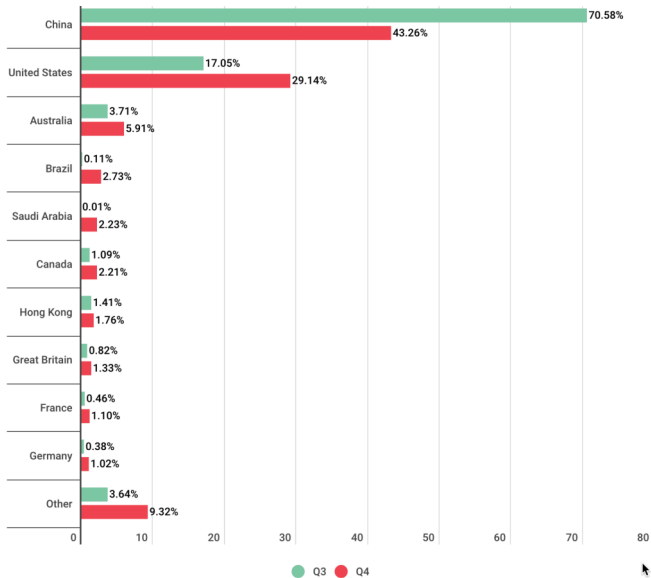
(Distributed) Denial of Service Attacks—Agenda

- Another very common type of attack
- Goal: **preventing legitimate users from accessing the system**
- Targets availability of the CIA triad
- How they work
- Mitigation approaches

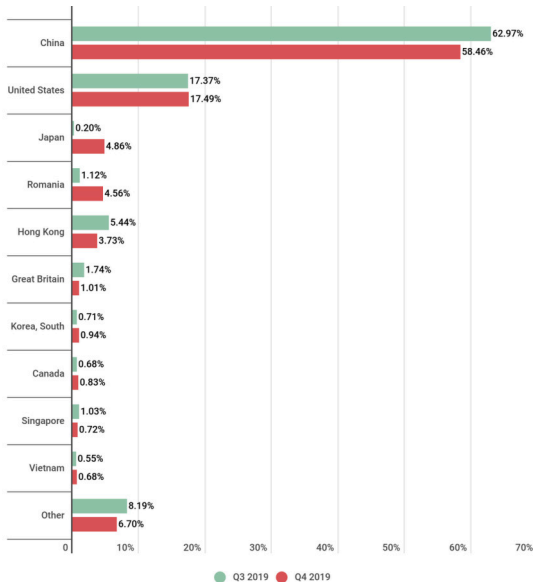
Attacked Resources by Countries Q3 2022



cmp. to Attack Targets by Countries 2018

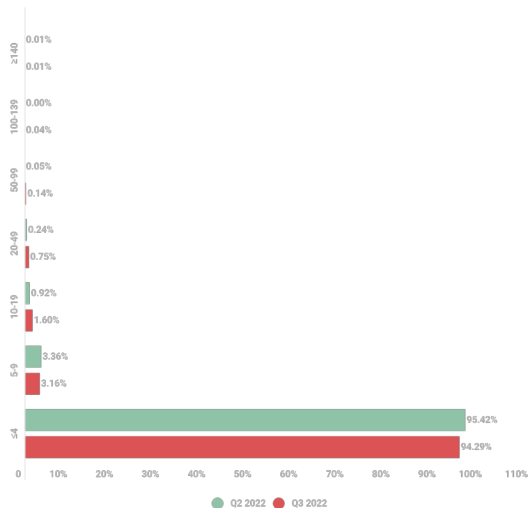


and Attack Targets by Countries 2019

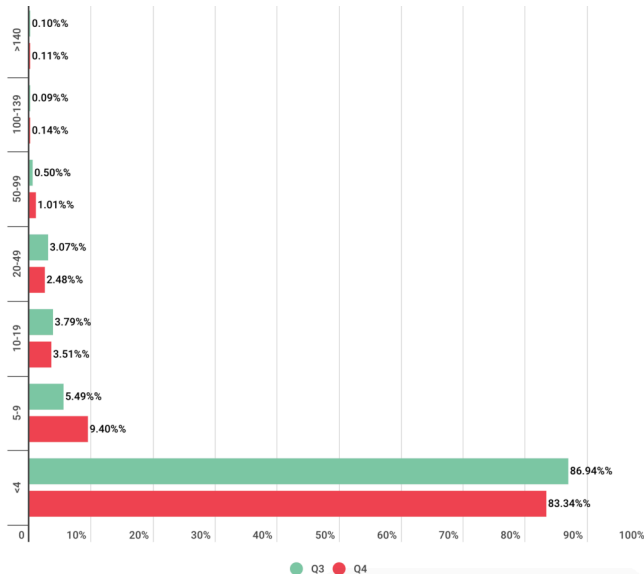


DDoS Attack Duration Q3 2022

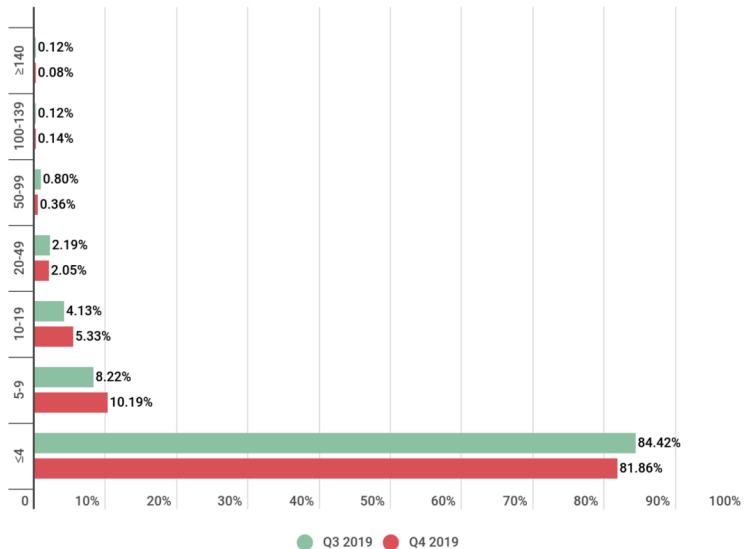
Note: Attacks shorter than 4h accounted for 60.65% of the total duration!



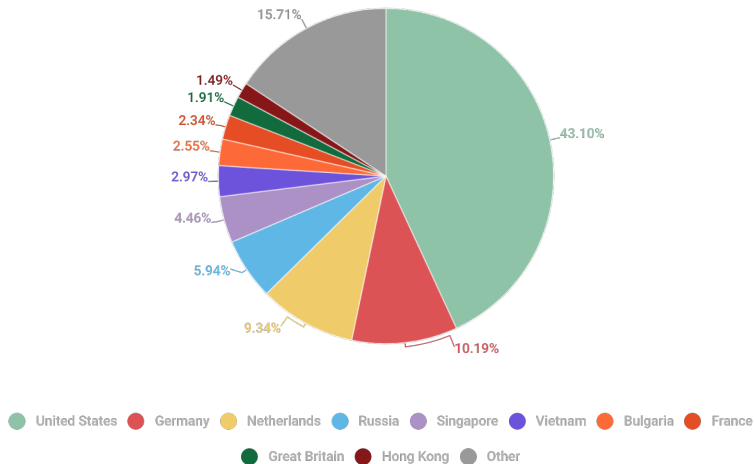
cmp. to Attack Duration in Hours 2018



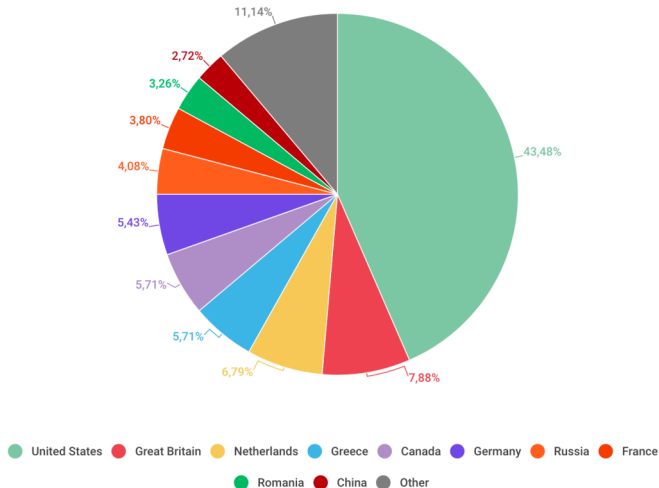
and Attack Duration in Hours 2019



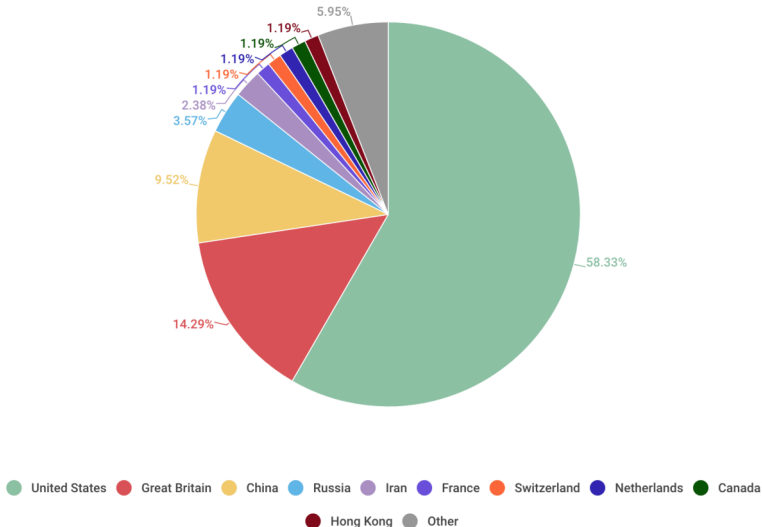
DDoS C&C Server Distribution Q3 2022



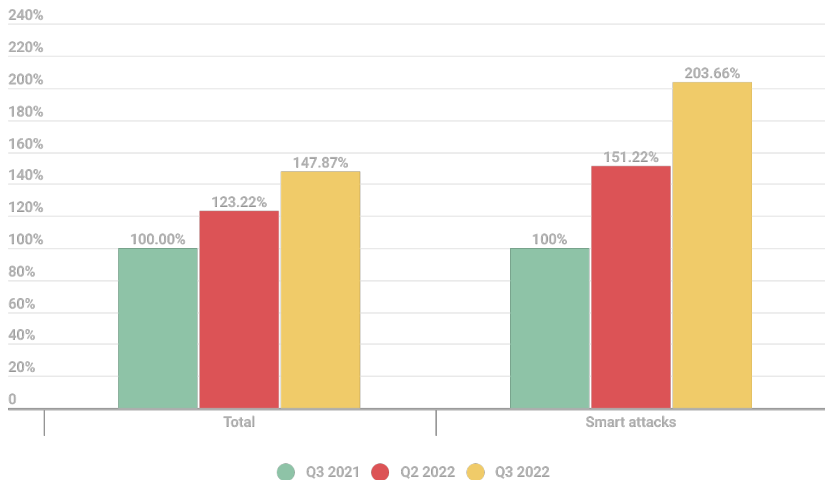
cmp. to DDos C&C Server Distribution Q4 2018



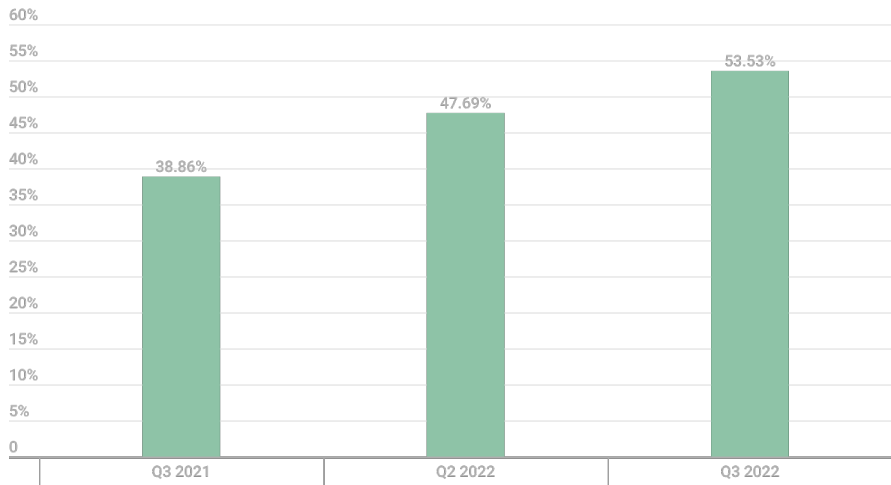
and DDos C&C Server Distribution Q4 2019



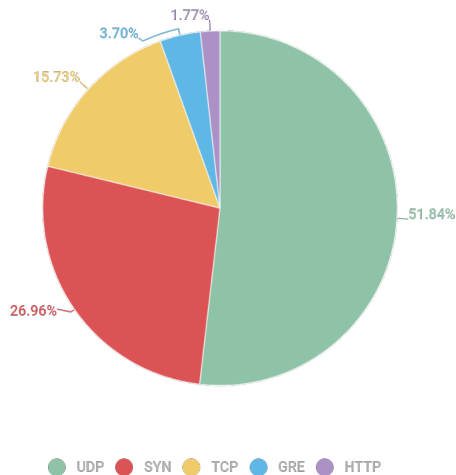
DDoS Attack Frequency Q3 2022



Smart Attack Frequency Q3 2022



DDoS Attack Types Q3 2022



TCP vs HTTP(s) Frequency Q3 2022



Relevance of DoS

- Why are DOS attacks possible and still so common?
- Physical / logical limitations create bottlenecks, e.g.
 - Number of users
 - Size of files
 - Bandwidth of connection
 - Number of parallel connection handshakes
 - Bandwidth of CPU computation
- Exceed any limit and response behaviour breaks down

Relevance of DoS

- Why are DOS attacks possible and still so common?
- Attacks are getting more complex
- Layer 4 attacks dwindle
- Layer 7 attacks on the rise
- There are many attack tools in easy reach
- Professionals tend to implement advanced attacks
- Hacktivists still tend to use simpler attacks

Common DoS Attack Types

(Distributed) Denial of Service Attacks

Ping of Death (PoD, 1997)

- TCP/IP IPv4 packets can be as large as 65 535 bytes¹
- Craft *fragmented* package going beyond this limit
- The result may be a buffer overflow, i.e., a system crash
- or even a remote code execution (RCE)
- Current OSes manage to deal with this issue (cmp. CVEs [CVE-2013-3183](#) and [CVE-2020-16898](#))
- Classical example for why to keep your systems updated (Linux patch [2:34:10 h after report](#) . ;-)

¹Actually, by now packets can *window scale* up to a gigabyte, [RFC 7323](#) .

SYN Flood (1996)

- Exploits the **TCP 3-way handshake**
 1. Attacker sends *SYN* packet
 2. Receiver sends *SYN-ACK*
 3. Receiver waits for final *ACK* (with timeout)
 - Attacker never sends the final *ACK* but floods with *SYN* packages
 - Bottleneck: full buffer for incomplete TCP connections (Earlier 1990s: ≈ 5 concurrent connection attempts)
- ⇒ Receiver cannot react to valid connection attempts

Smurf IP (1997)

Attack via broadcast ICMP echo request
with spoofed source IP pointing at victim

- Intermediaries respond with replies
- ICMP echo replies flood victim
- Network performs a DDoS on itself
- Defence on router level
(Default behaviour adjusted in Standards)



Teardrop Fragmentation Attack (1997)

Attack via crafted, fragmented TCP message

- TCP fragments overlap
- Victim system fails reconstructing the message
- Restarts or crashes vulnerable systems

Local Area Network Denial (Land, 1997)

Attack via endless forwarding loop, setting identical source and destination IPs and ports

- Attacker spoofs target/victim IP and Port in packets
- The victim machine enters a loop when replying to itself
- Very simple set up
- Fixed in 1997
- Resurfaced in Windows Server 2003 & Windows XP SP2

Mitigating DoS

(Distributed) Denial of Service Attacks

Mitigating SYN Floods

SYN Cookie: client response is verified, encoding relevant information as *cookie* in the sequence number.

RST Cookie: server replies with bad SYN-ACK, forcing a legitimate client to send a RST, thus verifying the client's interest in establishing a connection.

Stack Tweaking

- Reduce the timeout for accepting the final ACK
- Increase buffer size
- ...

Delays effect, but is not fixing the bottle neck.

Generic Mitigation

- **Firewalls,**
e.g., filtering ICMP and UDP ports prevents some LOIC DDoS attacks
- **Intrusion Detection/Prevention Systems (IDS/IPS),**
e.g., detect and block attacks, for example blocking the attacked service in the firewall
- **Updated systems,**
e.g., keeping AV signatures updated, OS and software patches current, preventing your machines to become zombies in a botnet used for an attack

Third Party Services

Websecurity services providing **reverse proxies** as frontends to your service.

- Many bottlenecks are real, e.g., try freeing up your internet connection
- Reroute traffic via data centres at multiple locations
- If one reverse proxy is attacked, others can take over
- Your service stays available
- Many providers, e.g., Cloudflare

Weaknesses DoS

(Distributed) Denial of Service Attacks

Weaknesses

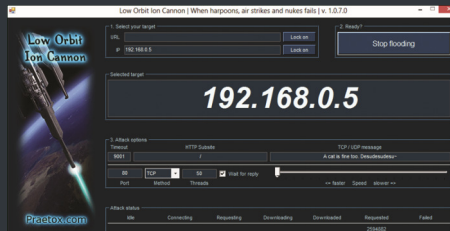
- Flood must be sustained
- Counter measures include taking down C&C servers
- Disinfecting machines also helps :-)
- When C&C server is taken over, attacker might be at risk of discovery
- Same when packets can be tracked
- Simple DoS might suffer from network bottle necks
- Without botnets, DDoS is difficult to achieve
- Simple firewall rules help against uniform attack pattern

Example (D)DoS Tools
—network stress testing tools—
(Distributed) Denial of Service Attacks

Low Orbit Ion Cannon (LOIC)

Open source network stress testing and DoS attack tool

- Easy to use GUI
- Target URL or IP
- TCP, UDP & ICMP flooding
- HTTP flooding



Low Orbit Ion Cannon (LOIC)

Limitations

- No IP spoofing
- I.e., doesn't hide IP
- Source traceable
- No DDoS
- That requires many volunteers

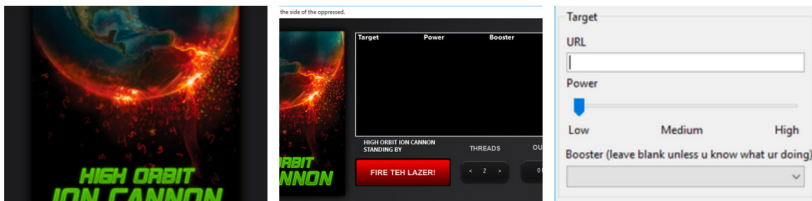
Used by **Anonymous** with many volunteers for DDoS attacks

- Church of Scientology (2010)
- Operation Payback (2010)
against companies opposing Wikileaks



High Orbit Ion Cannon (HOIC)

- Performs HTTP flood attacks
- Developed by Anonymous members
- Members were prosecuted during Operation Payback
- Designed to be effective with 50 users
- More needed against protected servers

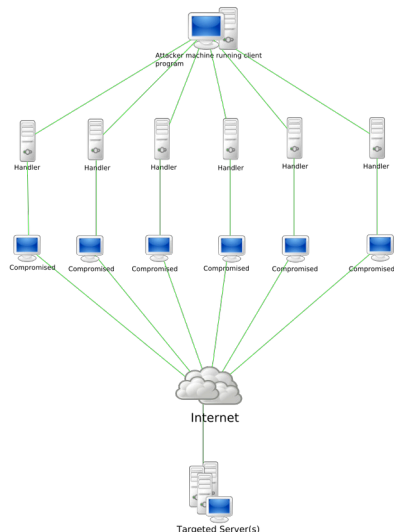


Tribal Flood Network (TFN) & TFN2K (1999)

- A set of programs to conduct DDoS
- SYN flood, UDP flood and Smurf attacks
- C&C support:
 - Master controls agents
 - Agents flood designated targets
 - Communications are encrypted
 - Communications can be hidden in traffic
 - Master can spoof its IP

Stacheldraht (1999, lit. barbed wire)

- ICMP Ping floods
- TCP SYN & UDP floods
- Smurf attack
- Source address forgery (IP address spoofing)
- Encryption
- Combining features of Trinoo & TFN



Slowloris

- Only Layer 7 tool in this list
- Slow, low bandwidth attack
- Ties up webserver's sockets
- Creating many connections and keeping them open
- ... as long as possible...
- making partial http requests
- [Original perl script from 2009](#) 
- [A python implementation](#) 

DoS—Summary

(Distributed) Denial of Service Attacks

DoS—Summary

- DoS attacks are common
- ... can be unsophisticated
- ... can be devastating
- ... but require many partners for effective operation (DDos)
- Vigilance at network and service level is required
- Companies provide protection on several layers, e.g., offering distributed gateways and reverse proxies in combination with high bandwidth networking

Applying Brute Force

Introduction

- A technique which lacks any sophistication
- Trial & error to determine invisible entities
 - user names
 - passwords
 - web server directories
- Can be performed locally,
e.g. John the Ripper (on a copy)
- Or remotely over a network
- Many specialised tools are available
(increasing the level of sophistication)

Remote Brute Force

- Hydra: parallelised login cracker 
supports parallelisation and *many* protocols
- Crowbar for OpenVPN, RDP, SSH private keys, VNC keys 
- Windows' 11s RDP gets default protection in July '22 
- A 10 min account lock after 10 invalid sign-in attempts
- What could possibly go wrong?

Sophisticating the Sledge Hammer

- Reduce the search space to gain speed
- For example with dictionary attacks
- Or personal information (birthdays, names)
- Past: security due to slow crypt()-routine
- Optimised versions changed the rules
e.g., Crack 3.2a, 1991
- Permute dictionary attacks with rules,
e.g., Crack 4.x, still 1991
- John the Ripper is a successor of Crack

Main Difficulty—A Noisy Affair

- An attack against the odds due to combinatorics
- Repeated trial & error *should* produce lots of noise
- A good system's logs will be flooded by messages
- But if the attacker can sneak away with the information ...

Attacker vs Defender I

- An attacker modulates attack patterns
- Distributes & delays
- Collects information to reduce the search space
- Uses statistics about common phrases & words
- Broad sweep vs. targeted attack

Attacker vs Defender II

- A defender tries to pick up on relevant patterns
- Disrupt ongoing attacks
- Make sure that combinatorics will be against the attacker
- Evening the odds for all passwords involved
- E.g., using password policies
- Checking against the same lists attackers use

Brute Force Relevance

- Especially for IoT or routers with default usernames/passwords
- Prediction: 29 billion IoT devices by 2023
- Brute force typically against telnet [SIC!] and ssh
- Trace developments with IoT honeypots
- First half 2023, 97.91% of attacks against telnet
- Aims: DDoS, Ransomware, DNS redirection, proxies
- “Services”: DDoS attacks, botnets, zero-day IoT vulnerabilities on Dark Net